Groundwork
SECURITY & COMPLIANCE

LETTER OF ATTESTATION

HIPAA Compliance.

PREPARED FOR NURSEPLEXUS INC.

A point-in-time review of administrative, technical, and physical safeguards for electronic protected health information.

BUSINESS ASSOCIATE · OCTOBER 1, 2026
GROUNDWORK SECURITY & COMPLIANCE · ST. LOUIS METRO

00 — CLASSIFICATION

For authorized use only.

This letter of attestation is issued by Groundwork Security & Compliance. It is intended solely for the information and internal use of Nurseplexus Inc. and is not intended to be, and should not be, used by any other person or entity.

ENTITY

Nurseplexus Inc.

HIPAA ENTITY TYPE

Business Associate

ATTESTATION DATE

October 1, 2026

CLASSIFICATION

Confidential

No other person or entity is entitled to rely, in any manner, or for any purpose, on this report. Document classification: Confidential. Company sensitive and proprietary.

PREPARED FOR

Nurseplexus Inc.
HIPAA Business Associate

PREPARED BY

Groundwork Security & Compliance
Jonathan Welzbacher, CISSP, CISA, CPA · Founder
jon@groundworksec.com · groundworksec.com

01 — ENGAGEMENT

About the organization.

Nurseplexus provides a cloud-based platform that streamlines the delivery of home infusion nursing services by connecting patients, nurses, agencies, pharmacies, and doctors in one secure ecosystem.

It offers end-to-end coordination—from referral intake, nurse matching, and scheduling to treatment documentation, follow-up visits, and outcome reporting—while giving nurses mobile access to patient records, real-time SMS requests, and schedule flexibility. Agencies receive integrated back-office dashboards, referral management, and recruiting tools, so pharmacies and providers can locate qualified nurses through dynamic, map-based tools.

Because some clients are HIPAA covered entities and required services that involved medical record numbers, it was determined that the organization must comply with the HIPAA requirements applicable to HIPAA business associates.

SECURITY RULE

What the Rule requires.

The Security Rule applies to health plans, healthcare clearinghouses, and any healthcare provider who transmits health information in electronic form in connection with a transaction for which HHS has adopted HIPAA standards (the “covered entities”) and to their business associates. The HITECH Act of 2009 expanded the responsibilities of business associates under the HIPAA Security Rule.

01
Confidentiality
Ensure the confidentiality, integrity, and availability of all ePHI they create, receive, maintain, or transmit.

02
Threats
Identify and protect against reasonably anticipated threats to the security or integrity of the information.

03
Use
Protect against reasonably anticipated, impermissible uses or disclosures.

04
Workforce
Ensure compliance by their workforce.

02 — SCOPE

What was reviewed.

This HIPAA compliance attestation was performed as a point-in-time discovery. Variances from the Security Rule were documented in a gap assessment plan. The assessment included a review of:

ENVIRONMENT
Network and endpoint computers

VENDORS
Third-party vendors

DATA
Databases and data stores

APPLICATION
Web application software

BUILD
Code, platform services, and APIs

PROGRAM
Policies and procedures

03 — ATTESTATION

The organization has documented and implemented substantive administrative, technical, and physical safeguards intended to address the data security risks associated with ePHI received from customers or their associates. This security plan was approved by management and is continuously monitored. This letter serves solely as an attestation that the described assessment and implementation activities were completed; it does not constitute an opinion, certification, or guarantee of compliance.

Groundwork Security & Compliance

Jonathan Welzbacher, CISSP, CISA, CPA
Founder · St. Louis metro · October 1, 2026

CONTACT
jon@groundworksec.com
618-520-8293
groundworksec.com

APPENDIX

Summary of HIPAA Rule controls reviewed.

This assessment included a review of the following HIPAA compliance controls.

FRAMEWORK CODE	TITLE	DESCRIPTION
164.308(a)(1)(i)	**Security violations managed**	The company has implemented policies and procedures to prevent, detect, contain, and correct security violations. If the company has committed to an SLA for a security violation, the corrective action is completed within that SLA.
164.308(a)(1)(ii)(A)	**Risks analyzed**	The company has conducted an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of electronic protected health information held in its system.
164.308(a)(1)(ii)(B)	**Risks managed**	The company has implemented security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level to comply with the HIPAA security general requirements (described in § 164.306(a)).
164.308(a)(1)(ii)(C)	**Sanction policy applied**	The company applies appropriate sanctions against workforce members who fail to comply with the security policies and procedures.
164.308(a)(1)(ii)(D)	**Information system activity reviewed**	The company has implemented procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking reports.
164.308(a)(5)(ii)(D)	**Passwords managed**	The company has implemented procedures for creating, changing, and safeguarding passwords.
164.308(a)(6)(i)	**Security incident procedures implemented**	The company has implemented policies and procedures to address security incidents.

APPENDIX · CONTINUED

FRAMEWORK CODE	TITLE	DESCRIPTION
164.308(a)(6)(ii)	**Security incidents identified and reported**	The company identifies and responds to suspected or known security incidents, mitigates, to the extent practicable, harmful effects of security incidents that are known to the company, and documents security incidents and their outcomes.
164.308(a)(7)(ii)(E)	**Application and data criticality analyzed**	The company assesses the relative criticality of specific applications and data in support of other contingency plan components.
164.308(a)(8)	**Security controls evaluated**	The company performs a periodic technical and nontechnical evaluation, based initially upon the HIPAA security rule, and subsequently, in response to environmental or operational changes affecting the security of electronic Protected Health Information (ePHI), establishes the extent to which the company's security policies and procedures meet the requirements of the HIPAA security rule (subpart C).
164.308(b)(1)	**Business associate contracts with vendors established**	The company, as a covered entity, permits a business associate to create, receive, maintain, or transmit electronic Protected Health Information (ePHI) on the company's behalf only if it can obtain satisfactory assurances, in accordance with company policies, that the business associate will appropriately safeguard the information.
164.308(b)(2)	**Business associate contracts with subcontractors established**	The company, as a business associate, may permit a business associate that is a subcontractor to create, receive, maintain, or transmit electronic Protected Health Information (ePHI) on its behalf only if the company can obtain satisfactory assurances, in accordance with company policies, that the subcontractor will appropriately safeguard the information.
164.308(b)(3)	**Business associate agreements documented**	The company documents the satisfactory assurances required for business associates and business-associated contractors through a written contract or other arrangements with the business associate that meets the applicable requirements of company policies.

APPENDIX · CONTINUED

FRAMEWORK CODE	TITLE	DESCRIPTION
164.310(a)(1)	**Facility access controls implemented**	The company has implemented policies and procedures to limit physical access to its electronic information systems and the facility or facilities in which they are housed while ensuring that properly authorized access is allowed.
164.310(a)(2)(ii)	**Facility security plan implemented**	The company has implemented policies and procedures to safeguard the facility and the equipment therein from unauthorized physical access, tampering, and theft.
164.310(a)(2)(iii)	**Access control and validation procedures implemented**	The company has implemented procedures to control and validate a person's access to facilities based on their role or function, including visitor control, and control of access to software programs for testing and revision.
164.312(c)(1)	**Data integrity maintained**	The company has implemented policies and procedures to protect electronic protected health information (ePHI) from improper alteration or destruction.
164.312(c)(2)	**Mechanism to authenticate ePHI implemented**	The company has implemented electronic mechanisms to corroborate that electronic protected health information (ePHI) has not been altered or destroyed in an unauthorized manner.
164.312(d)	**Person or entities authenticated**	The company has implemented procedures to verify that a person or entity seeking access to electronic protected health information is the one claimed.
164.312(e)(1)	**Data transmission secured**	The company has implemented technical security measures to guard against unauthorized access to electronic protected health information (ePHI) that is being transmitted over an electronic communications network.
164.314(a)(2)(i)	**Subcontractor agreements enforced**	The company has implemented policies and procedures to safeguard the facility and the equipment therein from unauthorized physical access, tampering, and theft.

APPENDIX · CONTINUED

FRAMEWORK CODE	TITLE	DESCRIPTION
164.314(b)(2)(i)	**Group health plan information controlled**	The company has implemented administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of the electronic protected health information (ePHI) that it creates, receives, maintains, or transmits on behalf of the group health plan.
164.314(b)(2)(iii)	**Group health plan information protected**	The company ensures that any agent to whom it provides this information agrees to implement reasonable and appropriate security measures to protect the information.
164.314(b)(2)(iv)	**Group health plan security incidents reported**	The company reports to the group health plan any security incident of which it becomes aware.
164.316(a)	**Policies and procedures created**	The company, as a covered entity or business associate, must, in accordance with the HIPAA security rule (§ 164.306), implement reasonable and appropriate policies and procedures to comply with implementation specifications, or other requirements, taking into account those factors specified in the HIPAA security general rules (§ 164.306(b)(2)(i), (ii), (iii), and (iv)). This standard is not to be construed to permit or excuse an action that violates any other standard, implementation specification, or other requirements (§164.316). A covered entity or business associate may change its policies and procedures at any time, provided that the changes are documented and are implemented in accordance with this subpart.
164.316(b)(1)(i)	**Policies and procedures documented**	The company maintains the policies and procedures implemented to comply with the HIPAA security safeguards in written (which may be electronic) form.
164.316(b)(1)(ii)	**Policies and procedures activity documented**	Where an action, activity or assessment is required (described in § 164.316) to be documented, the company maintains a written (which may be electronic) record of the action, activity, or assessment.

APPENDIX · CONTINUED

FRAMEWORK CODE	TITLE	DESCRIPTION
164.316(b)(2)(ii)	**Policies and procedures available**	The company makes documentation available to those persons responsible for implementing the procedures to which the documentation pertains.
164.316(b)(2)(iii)	**Policies and procedures updated**	The company reviews documentation periodically, and updates as needed, in response to environmental or operational changes affecting the security of electronic protected health information (ePHI).
164.410(a)(1), 164.410(a)(2)	**Notification of breach**	The company, as a covered entity, requires all business associates, following the discovery of a breach of unsecured protected health information, to notify the company of such breach. A breach is treated as discovered by a business associate as of the first day on which such breach is known to the business associate or, by exercising reasonable diligence, would have been known to the business associate. A business associate shall be deemed to have knowledge of a breach if the breach is known, or by exercising reasonable due diligence would have been known, to any person, other than the person committing the breach, who is an employee, officer, or other agents of the business associate (determined in accordance with the Federal common law of agency).
164.410(b)	**Timeliness of breach notification**	Except in cases of a law enforcement delay (§ 164.412), a business associate provides the breach notification required by the company Breach Notification policy (§ 164.410(a)) without unreasonable delay and in no case later than 60 calendar days after the discovery of a breach.
164.410(c)(1)	**Breach notice identification of individuals**	A business associate's breach notification includes, to the extent possible, the identification of each individual whose unsecured protected health information has been, or is reasonably believed by the business associate to have been, accessed, acquired, used, or disclosed during the breach.
164.404 (2), 164.404(a), 164.404(b), 164.404(c)(1), 164.404(c)(2), 164.404(d)(1)(i), 164.404(d)(1)(ii), 164.404(d)(2), 164.404(d)(2)(i), 164.404(d)(2)(ii), 164.404(d)(3), 164.406(a), 164.406(b), 164.406(c), 164.408(a), 164.408(b), 164.408(c), 164.410(c)(2)	**Additional breach information**	A business associate provides the company, as a covered entity, with any other available information that the company is required to include in notification to the individual (described in 164.404(c)) at the time of the notification or promptly thereafter as information becomes available.